

GUÍA METODOLÓGICA DETALLADA DE IMPLEMENTACIÓN

Encuesta de Madurez OWASP SAMM v2 + GQM + PRAGMATIC

Versión: 2.0 | **Fecha:** Enero 2026

Propósito: Implementar evaluación rigurosa de ciberseguridad de software

Duración total: 8-10 semanas de ejecución

FASE 0: PREPARACIÓN (Semana -1)

Paso 0.1: Definición de Alcance

Objetivo: Decidir **qué** se evalúa

Acciones:

1. Identificar límites de evaluación:
 - ¿Toda la organización o solo unidades específicas?
 - ¿Todas las aplicaciones o solo críticas?
 - ¿Qué versiones de tecnología incluyen?
1. Documentar restricciones:
2. Budget disponible
3. Timeline
4. Stakeholders disponibles

Entregable: Documento de alcance (1-2 páginas)

Paso 0.2: Asamblea de Stakeholders

Objetivo: Comunicar propósito y obtener buy-in

Acción:

- Sesión de 90 minutos con CISO, heads de departamentos
- Presentar: por qué SAMM, qué va a suceder, qué se espera de cada rol

Entregable: Agenda compartida; confirmación de participantes

FASE 1: DISEÑO DE LA ENCUESTA (Semana 1)

Paso 1.1: Seleccionar/Adaptar Cuestionario

Objetivo: Tener cuestionario personalizado listo

Acciones:

1. Usar template de modelo_encuesta_integral_samm.md como base
2. Adaptar lenguaje a contexto de tu org (ej: cambiar "apps críticas" a "sistemas del negocio")
3. Agregar 5-10 preguntas específicas si hay áreas de interés particular

Entregable: Cuestionario .xlsx o Google Form con 35-45 preguntas

Paso 1.2: Validación Interna

Objetivo: Asegurar que preguntas son claras

Acción:

- Sesión de 90 minutos (kickoff + calibración)
- Presente: CISO, 2-3 respondentes "piloto", facilitador
- Leer cada pregunta en voz alta; explicar criterios; recoger feedback

Entregable: Lista de cambios/aclaraciones para cuestionario

FASE 2: DISTRIBUCIÓN (Semana 2)

Paso 2.1: Identificar Respondentes

Objetivo: Seleccionar roles que aseguren triangulación

Recomendación: 10-13 respondentes de roles distintos

Rol	Cantidad	Por qué
CISO / AppSec Lead	1	Perspectiva estratégica
Arquitecto Sr	2-3	Visión de diseño
DevSecOps Lead	1-2	Perspectiva de tooling/automatización
Developer (Sr)	2	Perspectiva de desarrollo
QA/Tester	1-2	Perspectiva de verificación
SOC/SIEM Manager	1	Perspectiva operativa
Compliance/Audit	1	Perspectiva normativa

Paso 2.2: Comunicación a Respondentes

Objetivo: Maximizar tasa de respuesta

Acción:

- Email personalizado del CISO
- Incluir: contexto, duración (45 min), fecha límite, link a encuesta
- Ofrecer 15-min check-in call si necesitan aclaraciones

Entregable: Email + link a encuesta

Paso 2.3: Lanzamiento de Encuesta

Objetivo: Recopilar respuestas

Método:

- Google Form (gratis) o Qualtrics (si tienes presupuesto)

- Acceso anónimo si es posible (reducir sesgo)
- Duración abierta: 5-7 días

Entregable: Dataset de respuestas

FASE 3: RECOPIACIÓN DE DATOS TÉCNICOS (Semana 2-3)

Paso 3.1: Paralelo a Encuestas

Objetivo: Validar respuestas con datos objetivos

Acciones por métrica:

Métrica	Fuente	Recopilador
SAST coverage	CI/CD logs, scanner reports	DevSecOps
MTTD	SIEM/SOC tickets	SOC Manager
MTTR	Defect tracker	AppSec Lead
Phishing click-rate	Simulación platform	Security Awareness
Patch compliance	SCCM/Patch tool	Ops
Threat models	Repo/Wiki	Architects

Entregable: Spreadsheet con 10-15 métricas técnicas

FASE 4: ANÁLISIS (Semana 4)

Paso 4.1: Consolidación de Respuestas

Objetivo: Limpiar y normalizar datos

Acciones:

1. Cambiar N/A a promedio de otros respondentes (si <2 N/A por pregunta)
2. Si >2 N/A por pregunta: marcar como "brecha de visibilidad"
3. Calcular media, mediana, rango por pregunta

Entregable: Tabla resumen

Paso 4.2: Comparación Encuesta vs Datos Técnicos

Objetivo: Identificar discrepancias percepción vs realidad

Acción:

- Tabla cruzada: pregunta encuesta → métrica técnica → alineación

Ejemplo:

Pregunta: "¿Cobertura SAST?"

Respuesta media: 3 (mayoría de apps)

Dato técnico: 65% de builds con SAST activo

→ Alineación: Media, gap probable en onboarding

Entregable: Matriz de discrepancias

Paso 4.3: Cálculo de Scores

Objetivo: Generar IGM (Índice Global Madurez)

Método (ver documento Excel IGM):

1. Normalizar cada pregunta 0-1
2. Promediar por dominio SAMM
3. Aplicar pesos por dominio (ej: Gobernanza 15%, Diseño 15%, etc.)
4. Sumar → IGM 0-100

Ejemplo:

Gobernanza score: $2.1 / 4 = 0.525 \times 0.15 = 0.079$

Diseño score: $2.4 / 4 = 0.600 \times 0.15 = 0.090$

Implementación score: $3.0 / 4 = 0.750 \times 0.20 = 0.150$

... (más dominios)

IGM = 63/100

Entregable: IGM actual + scores por dominio

FASE 5: ANÁLISIS DE BRECHAS (Semana 5)

Paso 5.1: Identificar Top 3-5 Brechas

Objetivo: Priorizar áreas de mejora

Método:

1. Ranking de dominios por score (de menor a mayor)
2. Dentro de cada dominio débil, identificar preguntas con <2 pts
3. Cuantificar impacto (ej: "No hay threat modeling en 50% de apps críticas")

Entregable: Documento de brechas (1-2 páginas)

Paso 5.2: Mapeo a Regulación

Objetivo: Conectar brechas a requisitos regulatorios

Acción: Usar documento mapeo_preguntas_normativa.md

Ejemplo:

Brecha: MTTD 12 horas (vs objetivo 4h)

↓

Requisito: NIS2 Art. 21.2(c) "detección rápida de incidentes"

CRA Art. 10 "medidas operacionales de mitigación"

↓

Impacto regulatorio: Incumplimiento potencial en auditoría

Entregable: Tabla brecha – regulación

FASE 6: CASO DE NEGOCIO (Semana 6)

Paso 6.1: Definir Iniciativas

Objetivo: Proponer soluciones a brechas

Acción: Para cada brecha, definir iniciativa con:

- Nombre
- Descripción
- Métrica que mejora
- Coste estimado
- Timeline
- ΔIGM esperado

Ejemplo:

Iniciativa: SAST en CI/CD

- Descripción: Integrar scanner SAST en todos los builds
- Métrica: SAST coverage %
- Coste: €25k (herramienta + training)
- Timeline: 6 semanas
- ΔIGM: +5 puntos

Entregable: Portfolio de 5-10 iniciativas

Paso 6.2: Calcular ROI

Objetivo: Justificar inversión

Método (ver documento plantilla_excel_igm_roi.md):

1. Beneficio anual (ahorro por incidentes evitados, compliance risk reduction)
2. ROI simple: (Beneficio total 3 años - Coste) / Coste × 100
3. Payback: Coste / Beneficio anual

Ejemplo:

Iniciativa: SAST CI/CD

- Coste: €25k × 3 años = €75k
- Beneficio anual: €35k (reducción vulns pre-prod)
- Beneficio total 3 años: €105k
- ROI: (105k - 75k) / 75k = 40%
- Payback: 2.1 años

Entregable: Tabla ROI por iniciativa

FASE 7: REPORTERÍA (Semana 7)

Paso 7.1: Reporte Interno

Objetivo: Comunicar hallazgos a stakeholders

Estructura (30 páginas):

- Ejecutivo (2 pág): IGM actual/objetivo, top 3 brechas, recomendación
- Técnico (10 pág): Scores por dominio, análisis detallado
- Financiero (5 pág): Portfolio de iniciativas, ROI
- Regulatorio (5 pág): Brechas mapeadas a NIS2/CRA/GDPR
- Apéndices (10 pág): Datos detallados, metodología

Entregable: Reporte en PDF/Word

Paso 7.2: Presentación a CISO/Board

Objetivo: Obtener aprobación de roadmap

Duración: 45 minutos (usar template PowerPoint)

Agenda:

- 5 min: Contexto regulatorio (por qué ahora)
- 10 min: Hallazgos principales (IGM, brechas)
- 15 min: Iniciativas + ROI
- 10 min: Roadmap 12 meses
- 5 min: Próximos pasos

Entregable: Deck PowerPoint (14 slides)

FASE 8: APROBACIÓN E INICIO (Semana 8)

Paso 8.1: Presentación a Comité Directivo

Objetivo: Obtener presupuesto y patrocinio

Acción: CISO presenta a CFO, COO, otros VPs

Esperar aprobación de:

- ✓ Presupuesto Q1 (€10-15k típicamente para quick wins)
- ✓ Sponsorship de negocio
- ✓ Asignación de ownership

Entregable: Acta de decisión; presupuesto comprometido

FASE 9: IMPLEMENTACIÓN (Semanas 9-52, en paralelo)

Paso 9.1: Quick Wins (Q1)

Objetivo: Demostrar progreso rápido

Recomendación: 3-5 iniciativas, <€20k total, 6-8 semanas

Ejemplo:

- SAST en CI/CD
- Formación de phishing
- Scan de cobertura (SAST, SCA, DAST)
- Metrics dashboard
- Threat modeling training

Entregable: Iniciativas completadas

Paso 9.2: Consolidation (Q2)

Objetivo: Escalabilidad

Recomendación: +4 iniciativas, €15-20k

Ejemplo:

- DAST automatizado
- MTTR SLA tracking
- Secrets management
- Patch management improvements

Paso 9.3: Expansion (Q3-Q4)

Objetivo: Cobertura completa

Recomendación: +6 iniciativas, €30-40k

GUÍA RÁPIDA: TROUBLESHOOTING

Problema: Alta variabilidad entre respondentes

Causa probable: Falta de calibración o roles no alineados

Solución:

1. Ejecutar sesión calibración adicional
2. Entrevistar respondentes con mayor discrepancia
3. Investigar brechas de visibilidad (muchos N/A)

Problema: Datos técnicos no coinciden con encuesta

Causa probable: Métrica técnica está siendo "gamed" o encuesta mal interpretada

Solución:

1. Validar fuente de datos técnicos (¿está siendo reportada correctamente?)
2. Entrevistar respondentes para entender interpretación
3. Ajustar métricas si es necesario

Problema: Stakeholders no creen en resultados

Causa probable: IGM parece demasiado alto o bajo vs percepción

Solución:

1. Mostrar datos técnicos subyacentes
2. Explicar metodología de scoring
3. Hacer "sensitivity analysis" (qué pasa si pesos cambian)

CHECKLIST DE IMPLEMENTACIÓN

- ☐ Alcance documentado y aprobado
- ☐ Cuestionario adaptado y calibrado
- ☐ Respondentes identificados y comprometidos
- ☐ Encuesta distribuida y completada
- ☐ Datos técnicos recopilados
- ☐ Análisis consolidado (scores, brechas)
- ☐ Iniciativas y ROI definidos
- ☐ Reporte interno completo
- ☐ Presentación a CISO/Board realizada
- ☐ Presupuesto aprobado
- ☐ Quick wins iniciados